



HOW TO USE THIS

Work top to bottom and tick each box. Test in **layers** — prove the cloud function works on its own first, then activation, then login, then the gate — so when something fails you know exactly which layer to fix. The three boxes marked **CRITICAL** are the ones that hurt a real clinic if they break.

0 Before you start

- ☐ Mint test licenses with `dart run tool/license_tool.dart`: a valid **premium** (CL-TEST1), a valid **standard** (CL-TEST2), one **expired**, and a copy you will **tamper** (change one character of the signature).
- ☐ The RSA modulus is identical in `license_verifier.dart` and the Edge Function's `MODULUS_DEC`, both from the same key pair.
Expected: if they differ, every valid license fails — check this first.
- ☐ `.env` has `SUPABASE_URL` and `SUPABASE_ANON_KEY`.
- ☐ The function is deployed and listed:
Expected: `supabase functions deploy register-clinic` then `supabase functions list` shows it.
- ☐ macOS only: the network-client entitlement is set (otherwise cloud calls silently fail).
- ☐ You know the wipe command for a clean run:

```
find ~/Library -name 'dentos.db*' 2>/dev/null # then rm the files it lists
```

1 Test the Edge Function on its own

Hit the function directly with curl before opening the app. Build the body in a file so the shell never sees the JSON braces:

```
printf '{"email":"test1@demo.com","password":"secret123","license":"' > body.json
cat license.json >> body.json
printf '}' >> body.json

curl -i -X POST 'https://YOUR-REF.supabase.co/functions/v1/register-clinic' \
  -H "Authorization: Bearer YOUR_ANON_KEY" \
  -H "Content-Type: application/json" \
  --data-binary @body.json
```

- ☐ Valid license returns `{"ok":true}`.
Expected: Authentication > Users shows `test1@demo.com` with `clinic_id` in its metadata, and the clinics table has the CL-TEST1 row.
- ☐ A **tampered** license returns "License signature is not valid."
- ☐ An **expired** license returns "This license has expired."

Watch failures live with `supabase functions logs register-clinic`. A 401 means redeploy with `--no-verify-jwt`; a NOT_FOUND means it isn't deployed.

2 License & activation

- ☐ On a wiped DB, paste a **valid** license on the activation screen → it activates and advances; the **clinic name is locked** (read-only, from the license).
- ☐ A **tampered** license is rejected with “signature not valid.”
- ☐ An **expired** license routes to the Locked screen.

3 Setup + cloud registration

- ☐ **Online:** set username + email + password → Finish.
Expected: lands on the dashboard, a new auth user (tagged to this clinic) appears in Supabase, and the clinics row exists.
- ☐ **Offline:** turn off Wi-Fi, press Finish → it shows an error and the button becomes **Retry setup** → reconnect → Retry → it succeeds.
- ☐ Use a **unique email per clinic** in testing (a duplicate email is treated as “already set up”).

4 Local staff login (must work offline)

- ☐ Sign out, then sign in with the **owner username + password** → works.
- ☐ **Disconnect the internet completely** and sign in again → still works (login is local, not cloud).
- ☐ Enter a wrong password **5 times** → the account locks for 5 minutes.
- ☐ Lower the idle timer to ~30s temporarily, leave it idle → it auto-locks back to login.

5 Branch logins, seats & multi-device

- ☐ As owner (Premium): Settings → Staff → Add user → pick a branch → **Generate ID & password** → the one-time credentials card appears.
- ☐ Sign in as that branch user → they are **pinned**: the branch switcher is read-only and they only see that branch's patients, appointments, invoices and stock.
- ☐ Add users up to maxUsers → the Add button disables at the seat limit.
- ☐ Create a branch login on machine A → after a sync it appears in the Supabase users table → on machine B (same clinic) that login works.

6 Cloud sync & isolation

- ☐ Add a patient on A → it appears in the Supabase patients table → and on B after a sync.
- ☐ Edit the odontogram and create an invoice with line items → tooth_records / invoice_items round-trip to B.
- ☐ **CRITICAL** — Register CL-TEST2 with a different email, sign in, and confirm it sees **zero** of CL-TEST1's rows.
Expected: if it sees any, RLS is wrong — stop and fix before shipping.

7 The 48-hour gate, renewal & suspension

- ☐ Temporarily set the connectivity window to ~2 minutes, go offline past it → Reconnect screen → reconnect → it clears.
- ☐ **CRITICAL** — Record a contact, set the system clock **back** a day → it must **not** grant extra offline time (anti-rollback).
- ☐ In Supabase set `clinics.status = 'suspended'` (or `expires_at` in the past) → within the window the app locks; data stays intact.
- ☐ Mint a license with a later expiry + bump `clinics.expires_at` → paste it on the Locked screen → instant unlock.

8 Reset between runs & troubleshooting

To re-test the same clinic from scratch: wipe the local DB, and in Supabase delete the test **auth user**, the **clinics** row, and that clinic's data rows — otherwise the email is “taken” and old data syncs back.

Symptom	Fix
NOT_FOUND from curl	The function isn't deployed — run supabase functions deploy register-clinic.
“Malformed URL / nested brace”	Shell mangled the JSON — use the body.json file method above, not inline.
401 from the function	Redeploy with --no-verify-jwt, or send the anon key as the Bearer token.
“Signature not valid”	Modulus in the function/app doesn't match the signing key, or app not restarted after pasting.
Stuck on connection check	Auth user missing, .env not loaded, or (macOS) the network entitlement isn't set.

Do these three even if you skip the rest

1. Section 1 (function works in isolation). **2.** Section 6 cross-clinic isolation (RLS). **3.** Section 7 anti-rollback. These are the failures that actually harm a paying clinic.

DentOS internal test plan. Keep test licenses and your signing key confidential.